End-to-End Verifiable Online Voting without a Blockchain: Homomorphic Tallying and Zero-Knowledge Validity Proofs

Olivier P.

Abstract

In the 2022 French legislative elections, more than 77% of voters abroad voted online, but could not verify that their ballot was counted. We describe a Helios-type protocol in which (i) ballots are encrypted with additively homomorphic exponential ElGamal, so that the tally is computed on ciphertexts; (ii) each ballot carries non-interactive zero-knowledge proofs of validity; (iii) the decryption key is shared among trustees; (iv) every voter can check that their ballot is on a public bulletin board, and anyone can recompute the result. We state the security reductions, the soundness and zero-knowledge of the proofs, and a cost analysis showing that elections with 10^6 voters are verifiable on commodity hardware, with none of the energy cost of a public blockchain.

1. Requirements

An election has N eligible voters and a question with K options; voter i chooses $v_i \in \{0,1\}^K$ with $\ell \le \sum_j v_{ij} \le u$. We want: *correctness* (the published tally is $T_j = \sum_i v_{ij}$); *ballot privacy* (no coalition below a threshold learns more about v_i than what T reveals); *individual verifiability* (voter i can check that their ballot was recorded); *universal verifiability* (anyone can check that T is the tally of the recorded valid ballots); *eligibility* (one ballot per registered voter). A central server must not be trusted for any of these. We follow Helios [9], itself built on [6].

2. Homomorphic encryption

Let $\mathbb{G} = \langle g \rangle$ be a group of prime order q in which the decisional Diffie–Hellman (DDH) problem is hard [3] (a subgroup of $\mathbb{Z}_p^*$, $p = 2q+1$, or an elliptic curve). The secret key is $x \in \mathbb{Z}_q$, the public key $y = g^x$. Exponential ElGamal [7] encrypts $m \in \mathbb{Z}_q$ as

$$\mathsf{Enc}(m; r) = (\alpha, \beta) = (g^r,\ g^m y^r), \qquad r \xleftarrow{\$} \mathbb{Z}_q. \quad (1)$$

Proposition 1 (homomorphism)**.** $\mathsf{Enc}(m_1; r_1) \cdot \mathsf{Enc}(m_2; r_2) = \mathsf{Enc}(m_1 + m_2; r_1 + r_2)$ *componentwise.*

The proof is immediate. Hence $\prod_i \mathsf{Enc}(v_{ij}; r_{ij}) = \mathsf{Enc}(T_j; R_j)$, $R_j = \sum_i r_{ij}$: the tally is computed without decrypting any ballot. Decryption gives $g^{T_j} = \beta / \alpha^x$; since $0 \le T_j \le N$, T_j is recovered by baby-step giant-step [13] in $O(\sqrt{N})$ group operations, i.e. about 10^3 for $N = 10^6$.

Privacy. Under DDH, ElGamal is IND-CPA: $(g^r, g^m y^r)$ is indistinguishable from a pair of uniform elements. IND-CPA alone is not enough, since an adversary could copy and re-randomise someone else's ballot; attaching the proofs below makes the ballot non-malleable, and this is what yields ballot privacy in the random oracle model [2].

3. Zero-knowledge validity proofs

A malicious voter could encrypt $v_{ij} = 1000$. Each ballot therefore proves, without revealing v_i, that every $v_{ij} \in \{0,1\}$ and that $\sum_j v_{ij} \in [\ell, u]$.

Chaum–Pedersen. To prove that (α, β) encrypts a given m, i.e. $\log_g \alpha = \log_y (\beta g^{-m}) = r$: the prover sends $(a, b) = (g^w, y^w)$, receives a challenge $c \in \mathbb{Z}_q$, answers $z = w + cr$; the verifier checks

$$g^z = a\,\alpha^c, \qquad y^z = b\,(\beta g^{-m})^c. \quad (2)$$

Proposition 2. *This Σ-protocol [4] is complete, special sound and honest-verifier zero-knowledge.*

Proof. Completeness: $g^{w+cr} = g^w (g^r)^c$. Special soundness: two accepting transcripts (a, b, c, z), (a, b, c', z'), $c \neq c'$, give $g^{z-z'} = \alpha^{c-c'}$, hence the witness $r = (z - z')(c - c')^{-1} \bmod q$ satisfies both relations. HVZK: choose c, z uniformly and set $a = g^z \alpha^{-c}$, $b = y^z (\beta g^{-m})^{-c}$; this has exactly the distribution of real transcripts. □

Disjunction. To prove "$m = 0$ or $m = 1$" without revealing which, the prover simulates the false branch with a self-chosen challenge c_{1-m}, runs the true branch honestly with $c_m = c - c_{1-m}$, and the verifier checks both branches and $c_0 + c_1 = c$ [5]. The same technique applied to $\prod_j (\alpha_j, \beta_j) = \mathsf{Enc}(\sum_j v_{ij})$ proves $\sum_j v_{ij} \in \{\ell, \dots, u\}$. If a ballot is invalid, special soundness implies that a cheating prover succeeds with probability at most $1/q \approx 2^{-256}$.

Non-interactivity. With Fiat–Shamir [8], $c = \mathcal{H}(\text{statement}, a, b)$ for a hash function $\mathcal{H}$ modelled as a random oracle. The statement $(g, y, \alpha, \beta,$ election identifier$)$ *must* be hashed: the "weak" variant that hashes only (a, b) is unsound and broke the ballot privacy of early Helios versions [2].

4. Distributed decryption

The key is shared among n trustees: $x = \sum_k x_k$, $y = \prod_k g^{x_k}$ (or a Shamir t-of-n sharing [12, 11], so that $n - t$ trustees may be absent). Each trustee publishes $d_{jk} = \alpha_j^{x_k}$ with a Chaum–Pedersen proof that $\log_g y_k = \log_{\alpha_j} d_{jk}$, and $g^{T_j} = \beta_j / \prod_k d_{jk}$. A trustee who lies is detected with probability $1 - 1/q$; privacy holds unless t trustees collude, and no single server, hacked or dishonest, can decrypt an individual ballot.

5. Verification

Individual. The voter keeps $h_i = \mathcal{H}(\text{ballot}_i)$ and checks that h_i appears on the public append-only bulletin board; with collision-resistant $\mathcal{H}$, no other ballot can match. *Cast-as-intended* is checked with the Benaloh challenge [1]: before casting, the voter may ask the device to reveal r and check the encryption, then re-encrypt. A device that cheats on a fraction f of ballots, each audited with probability p, escapes detection on k ballots with probability $(1 - pf)^k$.

Universal. Anyone can recompute $\prod_i (\alpha_{ij}, \beta_{ij})$ from the board, check all validity and decryption proofs, and hence the tally: the result is correct as soon as all proofs verify, whoever ran the servers.

Eligibility. The board publishes a commitment per registered voter (a keyed hash of the identifier, not a plain hash of an e-mail, which can be reversed by dictionary search) and the number of ballots; any citizen can check that their commitment is listed and that #ballots $\leq$ #registered, which bounds ballot stuffing.

6. Cost and comparison

On an elliptic curve, a ballot with K options costs $2K$ exponentiations to encrypt and $O(K)$ more for the proofs; verifying a ballot also costs $O(K)$. For $N = 10^6$ and $K = 3$, universal verification is of the order of 10^7 exponentiations, i.e. minutes on a laptop, and it is embarrassingly parallel. A public blockchain (e.g. V8TE on Ethereum) provides an append-only board at a much higher monetary and energy cost; here the board only needs to be replicated and signed, since its integrity is checked by the hashes and proofs rather than by consensus.

Limits. The protocol is not receipt-free: a voter can prove their vote using r, which enables vote buying; coercion resistance requires credential-based schemes [10]. Privacy is computational (DDH), not everlasting.

7. Status

A prototype based on the Helios code base covers key generation, encryption, homomorphic tally, disjunctive proofs, trustee decryption and verification; next steps are threshold key generation, the Benaloh audit and large-scale benchmarks up to 10^6 voters.

References

[1] J. Benaloh. Simple verifiable elections. *USENIX EVT*, 2006.

[2] D. Bernhard, O. Pereira, B. Warinschi. How not to prove yourself: pitfalls of the Fiat–Shamir heuristic and applications to Helios. *ASIACRYPT*, 2012.

[3] D. Boneh. The decision Diffie–Hellman problem. *ANTS-III*, LNCS 1423, 1998.

[4] D. Chaum, T. Pedersen. Wallet databases with observers. *CRYPTO*, 1992.

[5] R. Cramer, I. Damgård, B. Schoenmakers. Proofs of partial knowledge and simplified design of witness hiding protocols. *CRYPTO*, 1994.

[6] R. Cramer, R. Gennaro, B. Schoenmakers. A secure and optimally efficient multi-authority election scheme. *EUROCRYPT*, 1997.

[7] T. ElGamal. A public key cryptosystem and a signature scheme based on discrete logarithms. *IEEE Trans. Inf. Theory* 31(4):469–472, 1985.

[8] A. Fiat, A. Shamir. How to prove yourself: practical solutions to identification and signature problems. *CRYPTO*, 1986.

[9] B. Adida. Helios: web-based open-audit voting. *USENIX Security*, 2008.

[10] A. Juels, D. Catalano, M. Jakobsson. Coercion-resistant electronic elections. *ACM WPES*, 2005.

[11] T. Pedersen. A threshold cryptosystem without a trusted party. *EUROCRYPT*, 1991.

[12] A. Shamir. How to share a secret. *Comm. ACM* 22(11):612–613, 1979.

[13] D. Shanks. Class number, a theory of factorization and genera. *Proc. Symp. Pure Math.* 20:415–440, 1971.